- OAuth 2.0 has multiple grant types representing common authorization flows. The authorization code flow with PKCE is the most common interactive grant type when a user initiates an interaction. For machine-only workflows, such as an API calling another API, you can use the client credentials grant type.
- OpenID Connect is built on top of OAuth 2.0. It adds conventions, discoverability, and authentication to OAuth 2.0, making it easier to interact with third-party providers and retrieve identity information about a user.
- JWTs are the most common bearer token format. They consist of a header, a payload, and a signature, and are base64-encoded. When receiving a JWT you must always verify the signature to ensure that it hasn't been tampered with.
- JWTs are not encrypted, so anyone can read them by default. JWE is a standard that wraps the JWT and encrypts it, protecting the contents. Many identity providers support generating JWEs, and ASP.NET Core supports decoding JWEs automatically.
- Bearer token authentication in ASP.NET Core is similar to cookie authentication with traditional web apps. The authentication middleware deserializes the token and validates it. If the token is valid, the middleware creates a `ClaimsPrincipal` and sets `HttpContext.User`.
- Configure JWT bearer authentication by adding the Microsoft.AspNetCore.Authentication.JwtBearer NuGet Package and calling `AddAuthentication()` `.AddJwtBearer()` to add the required services to your app.